Aiphone Firmware Attack Surface & Detection Brief

Aiphone Firmware Attack Surface & Detection Brief

Scope: CVE/public-advisory research, plus a real firmware acquisition and extraction attempt (update 2026-10-21). Real firmware was pulled for both product lines — IX-MV v8.30 (`IX-MV_V830.bin` , 30,035,984 bytes, SHA256 `92ff8f36ccf56e5ab47be505dc49777708a2 4651bebf5fb9936e37fbbffb15f5`) and IXG-2C7 v4.30 (`IXG-2C7_V430.bin` , 34,504,644 bytes, SHA256 not shortened here, see `firmware-staging/Aiphone/Intercom/*/catalog.csv`) — directly from Aiphone's open firmware archive, no login required. Both were run through this project's standard binwalk-based extraction pipeline (`Expand-EatonFirmware.ps1` + WSL/binwalk 3.1.0). **Result: zero binwalk signatures matched in either file** (85 file signatures / 187 magic patterns checked), and `strings` output on both is high-entropy, non-linguistic noise (23K+ "strings" that don't read as text) rather than the embedded readable strings a real filesystem or flat compiled binary normally carries. That pattern is consistent with the whole firmware image being encrypted at rest, not merely signed — binwalk cannot recognize or carve an encrypted container without the vendor's key, so no rootfs, service list, or config file could be extracted from either file. This is itself a real finding, not a null result to discard: it means Aiphone firmware updates likely can't be read or tampered with by an attacker who merely obtains the update file, a stronger anti-tamper posture than some other vendors already covered in this project (e.g. the Eaton brief's Group B finding that ESP32 NMC firmware flashes with no signature verification at all). Treat every CVE/advisory finding below as research-anchored, not firmware-verified — that part of the brief is unchanged by this extraction attempt. IX series and IXG series — the two product lines already staged in `firmware-staging/Aiphone/Intercom/` — are the research priority per the vendor's own October 2024 advisory cluster, which covers both lines under a single disclosure.

Purdue layer mapping: IX/IXG door and entrance stations directly actuate a physical door-strike relay (Aiphone's own network documentation names an explicit port — SSL/8620 — for "door release between two IX Series stations"), which is a field-device actuation role analogous to how this project's purdue-l1-basic-controllers-brief.md treats Eaton's UPS MCU family as "L0/L1-adjacent" despite not being a classic PLC/RTU/relay. **Verified by reading that document:** its current scope is industrial process control (chassis/compact PLCs, RTUs, protective relays, drives, DCS controllers) and it does not yet include physical-security/building-access devices — intercoms are not already covered there. This brief maps Aiphone IX/IXG to **Purdue L1 (Basic Controllers) by analogy**, not by inclusion: like the Eaton UPS MCU, it is a field-layer device whose primary function is direct actuation of a physical mechanism, and it would be a reasonable future addition to that cross-vendor brief as a "physical access actuator" class rather than a correction to treat as already covered. The IXG cloud gateway/mobile-app path (AiphoneCloud remote management) is the IT/OT-boundary-adjacent piece and would map closer to **Purdue L3.5** if that specific gateway function were addressed in purdue-l35-it-ot-boundary-brief.md.

Architecture grouping (drives the threat model, not the SKU)

Class	Purdue layer (by analogy)	Products	Stack	Research depth
A. IX Series	L1-adjacent (field actuation)	IX-MV7 master stations; IX-DA/DB/EA/DV/DVF/DVM video door stations; IX-SS-2G/SSA/RS audio door & sub stations; IXW-MA adaptor; legacy IX-1AS/IX-10AS/IX-PA adaptors	Embedded Linux (kernel 2.6 on most legacy stations, 3.10 on IX-MV7 per Aiphone's own OS-version listing); peer-to-peer — all stations on one logical L2 network, no central controller required	research-only (no firmware pulled yet)
B. IXG Series	L1-adjacent (field actuation) + L3.5-adjacent (cloud gateway)	IXG-2C7/2C7-L tenant stations; IXG-DM7 family entrance stations; IXG-MK guard station; IXGW-GW/TGW gateway adaptors (AiphoneCloud remote management + mobile app); IXGW-LC lift-control adaptor	Embedded Linux (2.6 on most IXG stations, 3.10 on IXGW-GW); SIP/ONVIF-compliant; 2024 firmware update converged the IX and IXG codebases (per Aiphone's own product announcement), which is consistent with the Oct 2024 CVE cluster affecting both lines identically	research-only
C. GT-DMB entrance stations (video multi-tenant)	L0/L1-adjacent (physical access control)	GT-DMB, GT-DMB-N, GT-DMB-LVN, GT-DB-VN	Distinct product family from IX/IXG — NFC-based admin passcode + tag provisioning subsystem; not currently staged in `firmware-staging/Aiphone/`; flagged here because it carries the clearest documented unauthorized-door-unlock finding in the vendor's history	research-only, out of current staging scope

---

Group A/B — IX / IXG Series: confirmed attack surface (from Aiphone's own network documentation)

Aiphone's own **"IX Series Network and Security Summary"** application note (dated 04/22, fetched and read directly in this research — PDF) documents the following factory-state attack surface. The 2024 IX/IXG codebase convergence means this table is a reasonable proxy for IXG as well, though Aiphone publishes a separate IXG network-security-summary note that this research could not fully retrieve (page returned HTTP 410 at the time of this research).

```
HTTP/80 (CGI commands, not adjustable) · HTTPS/443 (web config + CGI, TLS 1.2) ·
SIP/5060 UDP (station-to-station + SIP server, adjustable) ·
RTP 20000-21000 (audio) · RTP 30000-31000 (video) · RTSP/554 · ONVIF/10080 ·
IGMP/MLD (multicast join/leave for paging) · SFTP/22 (setting-file upload, "cannot be disabled") ·
SMTP/25 · DHCP/68 · NTP/123 · DNS/53 ·
UDP/55550 (paging control) · UDP/55552+ (paging audio) · TCP/10000 (SIF event messages) ·
SSL/8620 — door release between two IX Series stations ·
UDP/8700 (all-subnet broadcast, station search/association) · UDP/65014 (IXW-MA)
```

Factory-default credentials, per Aiphone's own documentation: IX Support Tool ID/password default to `admin` / `admin`, and IX Stations ID/password also default to `admin` / `admin`, until an installer changes them. The same application note states the Support Tool's generated configuration files "contain specific passwords

stored in plain text" and warns that "an experienced user could read this configuration file and discover the admin password for the stations" — a vendor-documented credential-exposure risk independent of any CVE. Separately, Aiphone's own documentation states that the **legacy IX-1AS, IX-10AS, and IX-PA adaptors do not use SSL or TLS at all, nor do they accept SSH configuration** — their web configuration (port 80) is unauthenticated-transport by design, and Aiphone's only stated mitigation is network ACLs/VLAN isolation.

Confirmed CVEs (IX/IXG cluster, disclosed October 2024 via JPCERT/CC + JVN#41397971, reported by Vera Mens of Claroty Research — Team82):

CVE	CWE	CVSS v3.0	Product / firmware	Vector
CVE-2024-31408	CWE-78 OS Command Injection	8.0 (AV:A/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H)	IX SYSTEM firmware Ver.7.10/7.11 and earlier (IX-MV, IX-DA/DB/EA/DV/DVF family, IX-BA/BB, IX-SSA/RS, IXW-MA, etc.)	Network-adjacent **authenticated** attacker can run arbitrary OS commands as root
CVE-2024-39290	CWE-522 Insufficiently Protected Credentials	6.5	IX SYSTEM and IXG SYSTEM, same firmware floor as above plus IXG-2C7/2C7-L (Ver.3.01-), IXG-DM7/MK (Ver.3.00-), IXGW-GW/TGW (Ver.3.01-), IXGW-LC (Ver.3.00-)	Network-adjacent **unauthenticated** attacker can obtain stored credentials (username/password) from the station address book
CVE-2024-45837	CWE-321 Use of Hard-coded Cryptographic Key	5.4	IX SYSTEM Ver.7.30/7.31 and earlier; IXG SYSTEM (same models as above); IX-SupportTool Ver.10.3.0.0-; IXG-SupportTool Ver.5.0.2.0-	Network-adjacent **unauthenticated** attacker can log into the SFTP service (the vendor-documented port 22 "setting file upload" service, which Aiphone states "cannot be disabled") without credentials, and read/modify files
CVE-2024-47142	CWE-522 Insufficiently Protected Credentials	5.5	IXG SYSTEM firmware Ver.2.03 and earlier — IXG-2C7, IXG-2C7-L only	Network-adjacent **authenticated** attacker can perform unintended operations

No fixed-version numbers are published on the vendor's public advisory landing pages (IX advisory, IXG advisory); both pages direct customers to the latest firmware without stating the patched build. This is itself a finding worth flagging: confirming whether any deployed device in the 246-unit census is on a fixed build requires either pulling the current firmware archive or direct vendor/integrator confirmation — neither is possible from CVE research alone.

No CISA ICS advisory exists for Aiphone as of this research. Direct searches of CISA's ICS-advisory feed and the CISA Known Exploited Vulnerabilities (KEV) catalog returned no Aiphone entries. Coordination for the October 2024 cluster ran through Japan's JPCERT/CC and IPA via JVN (JVN#41397971), not CISA — plausible given Claroty's reporting channel and Aiphone's Japanese parent entity, but it means this vendor's

vulnerabilities will not surface in a CISA-advisory-only monitoring workflow. None of the five Aiphone CVEs above appear in the CISA KEV catalog, i.e., no confirmed in-the-wild exploitation is publicly documented for any of them.

Group C — GT-DMB multi-tenant entrance stations: the clearest unauthorized-door-unlock finding

This is a **different Aiphone product family from IX/IXG** (video multi-tenant entrance systems), not currently staged in this project's firmware-staging tree, but it is the vendor's most directly relevant precedent for the "unauthenticated door-release" concern that IP-intercom systems carry as a product category.

CVE	Product / firmware	Vector	Impact
CVE-2022-40903	GT-DMB, GT-DMB-N, GT-DMB-LVN (fixed firmware Ver.3.00+); GT-DB-VN (fixed Ver.2.00+) — units manufactured before Dec 7, 2021 affected	NFC-based attack: an attacker uses a custom Android app (imitating Aiphone's official admin tool) on an NFC-capable phone to brute-force the 4-digit admin passcode, then injects a device serial number to register a new NFC tag	Unauthorized building entry via the newly-registered NFC tag — **no button press, no alarm**. Per Promon (the discovering researcher) the affected devices **do not store access logs**, so an organization cannot detect that an intrusion occurred. Aiphone confirmed the flaw cannot be fixed by firmware update — affected hardware requires physical replacement. CVSS 4.3 per JVN; disclosed by Cameron Palmer of Promon, published by Aiphone Nov 10, 2022.

This is the strongest real-world precedent found in this research for "unauthenticated door-release/unlock" as a genuine Aiphone-specific finding (not an assumption about the IP-intercom category in general) — though it sits on a different product line than the 246 IX/IXG-class devices expected in this census. If any GT-series units are later identified in the inventory, this CVE should move to the front of the queue.

Top attack vectors (MITRE ATT&CK ICS)

1. **T0812 Default Credentials** — Aiphone's own documentation confirms `admin` / `admin` as the IX/IXG factory default for both the Support Tool and the stations themselves. This is a vendor-documented fact, not a CVE, and is the single highest-value, zero-research-cost check for any deployed unit.
2. **T0882 Theft of Operational Information** — CVE-2024-39290 (unauthenticated address-book credential disclosure) is a direct instance of this technique against the station itself.
3. **T0866 Exploitation of Remote Services** — CVE-2024-45837 (hard-coded key enabling unauthenticated SFTP login) and CVE-2024-31408 (authenticated OS command injection to root) both land here; the SFTP service is the exact vendor-documented port-22 "setting file upload" function that Aiphone states "cannot be disabled."
4. **T0836 Modify Parameter** — once SFTP write access is obtained via CVE-2024-45837, station configuration (including the `admin` / `admin` -reachable settings and address-book data) is directly modifiable.
5. **T0855 Unauthorized Command Message** — the vendor-documented SSL/8620 "door release between two IX Series stations" channel is the literal unlock-command path; no public CVE was found

specifically against this channel's authentication, but it is the highest-consequence message type on the wire and merits direct testing once firmware/traffic capture is available.

Logging/detection matrix (ordered by detection value)

#	Source	Event	What it catches	MITRE ATT&CK ICS
1	**Network IDS (Suricata/Zeek)**	Inbound connection to TCP/22 (SFTP) on any IX/IXG station from a non-Support-Tool management host	CVE-2024-45837 hard-coded-key SFTP exploitation	T0866 Exploitation of Remote Services
2	Network IDS	HTTP/80 or HTTPS/443 `POST` login to a station or IX Support Tool host using `admin` / `admin`, especially a first-time success from a non-installer subnet	Default-credential takeover (T0812)	T0812 Default Credentials
3	**Network IDS**	SSL/8620 session (door-release channel) opened between two stations outside normal visitor-call hours, or from a host that is not a registered station	Forged/replayed door-release command	T0855 Unauthorized Command Message
4	Network IDS	SIP/5060 traffic to a station from a source outside the station's peer-to-peer logical network (the IX Series is peer-to-peer by design — any external SIP peer is anomalous)	SIP enumeration / rogue call injection	T0866 Exploitation of Remote Services
5	Network IDS	Repeated CGI command requests to HTTP/80 (particularly against legacy IX-1AS/IX-10AS/IX-PA adaptors, which Aiphone states have no TLS/SSH at all)	Command injection probing (CVE-2024-31408-class) on the unencrypted legacy adaptor surface	T0866 Exploitation of Remote Services
6	Station/door event log (where supported)	Door-release event outside posted access hours, or release events with no preceding call/badge event	Unauthorized unlock (the GT-DMB CVE-2022-40903 pattern: "no logs" on affected hardware is itself a detection gap to flag)	T0855 Unauthorized Command Message
7	IX Support Tool host (Windows)	File-system access to Support-Tool-generated configuration files by any account other than the installer	Plaintext-password harvesting from config files (vendor-documented risk)	T0882 Theft of Operational Information
8	Firewall / network segmentation	Any IX/IXG station or IXGW-GW/TGW gateway originating outbound traffic to a non-AiphoneCloud, non-RFC1918 destination	Compromised station calling out, or unexpected cloud-gateway behavior	T0866 Exploitation of Remote Services

Secondary:

- Firmware-update events: Aiphone's public advisories for the Oct 2024 cluster do not state a fixed firmware version on the landing page, so any firmware-update event log should be cross-checked manually against the version floors in the CVE table above once a specific device's current version is known.

- Multicast/paging anomalies: the IX Series uses mandatory multicast for "All Call" paging (per Aiphone's own documentation) — unexpected IGMP join/leave activity or paging-control traffic (UDP/55550) outside scheduled announcements is worth a baseline alert.
- SIP call-detail anomalies: off-hours call volume, calls to/from stations not in the address book, or SIP registration attempts from unexpected source IPs — standard SIP telephony-security monitoring applies directly to this product class.

Specific concerns for this dataset

1. **246 devices makes Aiphone a top-tier OT vendor by device count in this census** — larger than most of the classic industrial-process-control vendors this project has already briefed (Rockwell, SEL, Siemens PLCs barely register in this specific inventory). That scale, combined with the vendor-confirmed `admin` / `admin` factory default and the plaintext-password-in-config-file behavior, means a credential sweep across all 246 units is plausibly the single highest-value, lowest-cost action available to this program before any firmware extraction happens — it requires no CVE research, just confirming whether default credentials were ever changed at install time.
2. **No CISA ICS advisory and no KEV entry exists for this vendor.** Any detection/patch program keyed only to CISA ICS advisories or KEV will silently miss all five Aiphone CVEs identified in this research. JVN/JPCERT-sourced advisories need to be a tracked feed for this vendor specifically.
3. **The firmware-fix-version gap is a real operational blocker.** Aiphone's public advisory pages for the October 2024 cluster do not state which firmware version remediates the four CVEs — "update to the latest" is not independently verifiable without either the firmware archive (openly downloadable, not yet pulled) or a device-by-device version check. This should be the first fast-follow action.
4. **Physical door-strike actuation with a documented plaintext-credential-exposure path is a materially different risk class than this project's typical process-control findings** — a compromised Aiphone station is not "manipulate a setpoint," it is "open a door," and for a National Guard physical-security context that is a direct, not derivative, risk.
5. **GT-DMB-class hardware-only-fix / no-access-logs finding (CVE-2022-40903) is a useful cautionary pattern even though it's a different product line** — if the census ever turns up GT-series devices (it currently resolves vendor-only by OUI, per the staging README's own caveat, so model confirmation is still open), this is the first thing to check, because the vendor's own statement is that older affected units cannot be patched at all.

Sources

- JVN#41397971 — Multiple vulnerabilities in IX System, IXG System, and System Support Software
- CVE-2024-31408 (NVD)
- CVE-2024-39290 (NVD)
- CVE-2024-45837 (NVD)
- CVE-2024-47142 (NVD)
- Aiphone IX System vulnerability notice (Oct 16, 2024)
- Aiphone IXG System vulnerability notice (Oct 16, 2024)
- JVN#75437943 — Information disclosure in Aiphone Video Multi-Tenant System Entrance Stations

- CVE-2022-40903 context — SecurityWeek: "Aiphone Intercom System Vulnerability Allows Hackers to Open Doors"
- Aiphone — IX Series Network and Security Summary (application note, 04/22)
- Aiphone — IX and IXG Series Station Operating System (OS) Versions
- Aiphone IX|IXG firmware archive (open access, no login)
- CISA Known Exploited Vulnerabilities Catalog — searched directly; no Aiphone entries found
- CISA ICS Advisories index — searched directly; no Aiphone-specific advisory found
- MITRE ATT&CK for ICS — T0812 Default Credentials
- MITRE ATT&CK for ICS — T0836 Modify Parameter
- MITRE ATT&CK for ICS — T0855 Unauthorized Command Message
- MITRE ATT&CK for ICS — T0866 Exploitation of Remote Services
- MITRE ATT&CK for ICS — T0882 Theft of Operational Information
- purdue-l1-basic-controllers-brief.md — cross-vendor L1 brief (read to verify current scope before mapping Aiphone to it)